

Cybersecurity Policy Generation via Ontology-Driven Knowledge Graphs and Multi-Dimensional Similarity Scoring

Research Question: How does ontology-grounded generation affect the accuracy, specificity, and faithfulness of cybersecurity policy drafting compared to ungrounded LLMs?

Authors: Chris Rezny, Shikha Sharma

Abstract

Cybersecurity frameworks such as NIST CSF, SOC 2 and ISO 27001 are difficult and time-consuming to translate into enforceable internal policies due to their complexity and the need for precise, framework-aligned language. We address this challenge by modeling cybersecurity framework control areas, sub-controls, and evidence requirements in a Neo4j knowledge graph and enriching this structure with organization-specific ontologies. A cybersecurity-domain sentence encoder (CyberBERT+ [1]) is used to extract atomic requirements that condition retrieval-augmented generation. Four open-source LLMs were evaluated against ~500 policy sections where baselines showed high semantic similarity, but very low lexical and structural alignment, confirming that semantic understanding is insufficient for policy drafting. Evaluation is conducted using a Multi-Dimensional Similarity (MDS) metric that integrates semantic similarity, lexical precision, ontology alignment, RAGAS faithfulness, and length conformity. Ontology-grounded RAG combined with LoRA fine-tuning showed statistically significant improvements in specificity, accuracy, and framework faithfulness compared to ungrounded generation, with DPO identified as a promising direction for future enhancement.

1. Introduction

Cybersecurity frameworks are published by various organizations including the National Institute of Standards and Technology, the American Institute of Certified Public Accountants, and the International Organization for Standardization to guide organizations in structuring their security programs. They inform policy creation, demonstrate due diligence, and meet regulatory expectations. In each framework are specific control areas and sub-controls that give guidance in how the organization can protect itself against various risk vectors and how to mitigate them. Although their purposes differ, they share a similar hierarchical structure and must be interpreted and expressed as enforceable internal policies.

The Problem:

Many cybersecurity policies fail to achieve their intended purpose because they lack clarity, practicality, and are written in ways that employees cannot easily understand [2]. Security teams must determine which requirements apply to their environment, articulate them in precise, auditor-ready language, and maintain consistency across dozens of interconnected policies. For small and medium-size organizations without dedicated staff this task becomes extremely resource intensive and prone to mistakes. These mistakes make any audit process take longer, create more work for already overworked staff, and can leave the organization vulnerable to bad actors that may look to exploit the shortcomings.

Limitations of Existing Approaches:

Large language models (LLMs) seem like a natural fit for drafting policy text. However, relying on simple prompt engineering typically produces phrases that are generic, stylistically inconsistent, or unfaithful to the framework. Providing additional information from the framework or information about the organization requiring the policy increases the likelihood of hallucinations [4]. Recent research indicates that grounding LLM generation with specific ontology demonstrates that structured knowledge can significantly improve the validity of the generated output [3], reduce hallucinations [4][5], and increase domain-specific correctness. These limitations make ungrounded LLM generation unsuitable for producing reliable cybersecurity policy documentation.

Our Approach:

Building on the existing research we develop an ontology-grounded approach to cybersecurity policy generation. It combines framework ontologies, organizational details, and atomic requirement extraction with retrieval augmented LLM generation. We represent SOC 2 and NIST CSF frameworks as hierarchical knowledge graphs in Neo4j, use CyberBERT+, to extract atomic requirements and align those requirements with specific policy clauses. We use the mappings and requirements as conditioning signals in our RAG pipeline. Finally we introduce a Multi-Dimensional Similarity (MDS) metric that jointly measures semantic fidelity, lexical precision, ontology coverage, and structural conformity. All of these combined allow for a comparison of ungrounded, ontology-grounded, and LoRA-fine-tuned policy generation.

2. Background and Related Work

Cybersecurity policies are traditionally created by individuals and struggle to translate broad framework requirements into actionable documentation. Gartner's 2024 [1] research notes that many cybersecurity policies fail because they lack clarity, practicality, or actionability and employees often find them difficult to understand. This problem is made worse by how modern cybersecurity frameworks are structured. The control areas, sub-controls, and evidence requirements form dense, hierarchical standards that require careful interpretation before they can be expressed as enforceable policy language.

As large language models have improved, researchers have begun exploring whether structured knowledge can help reduce hallucinations and improve domain accuracy. OG-RAG (Sharma et al., 2024) [5] showed that grounding retrieval in formal ontologies can substantially improve factual recall and response correctness. OPAL (Chen et al., 2023) [3] demonstrated that incorporating ontology representations during pretraining helps models follow constraints and maintain domain consistency. While others have focused on improving verifiability, such as the symbolic reference approach of Hennigen et al. (2024) [4], and on improving guideline following behavior as shown by Wen et al. (2025) [6]. Together, these findings suggest that LLMs benefit from structured semantic grounding, particularly in domains that require adherence to formal rules.

Despite advances in ontology-grounded generation, prior work has focused on conversational systems, scientific QA, and biomedical reasoning. Cybersecurity policy drafting remains largely unexplored, with existing approaches relying on templates, unstructured prompting, or manual authoring. This gap presents an opportunity that we hope to address. We apply ontology-grounded generation to the cybersecurity domain by modeling framework hierarchies as knowledge graphs, using atomic requirements to enhance retrieval-augmented policy drafting and fine tuning a model on SME supplied text.

3. Methods

High-Level Design:

We leveraged structured cybersecurity ontologies, atomic requirement extraction and retrieval-augmented generation into a unified pipeline to produce reliable and focused cybersecurity policy clauses. We focused on individual clauses inside a larger policy to limit the drift of the response of the LLM. Shorter, more directed requests produce better AI generated results. We leveraged established techniques such as domain-specific sentence embeddings (CyberBERT+), hierarchical knowledge graph modeling, and retrieval-augmented prompting with our two novel concepts: (1) a framework aligned knowledge graph that relates SOC 2 and NIST CSF control areas to sub-controls to evidence requirements and finally to specific policy sections. And (2) a Multi-Dimensional Similarity (MDS) metric that evaluates semantic fidelity, lexical precision, ontology coverage, and structural conformity.

This approach is appropriate for the creation of Cybersecurity policy drafting because the frameworks are highly structured and contain multi-dimensional obligations. Frameworks specify control intent, which requires strong semantic fidelity to preserve the meaning of the requirement. They rely on strict terminology, “logical access,” “monitoring,” and “evidence requirements”, which demand high lexical precision. Each control is connected to specific sub-controls with evidence expectations and action items requiring strong ontology coverage to ensure the generated text reflects all obligations. Finally, auditors expect a consistent clause structure and explicit operational detail, requiring structural conformity.

Problem Description: The primary challenge in cybersecurity policy creation is the disconnect between the requirements found in the framework and the specific language needed for the required policy. For example SOC 2 Risk Identification and Analysis (Principle 7) (CC3.2) states:

“The entity identifies risks to the achievement of its objectives across the entity and analyzes risks as a basis for determining how the risks should be managed.”

The phrase in the Enterprise IT Risk Management Policy from our dataset, created by a subject matter expert (SME), reads:

“Risk analysis activities involve qualitative and quantitative assessments of risk factors, threats, and vulnerabilities. [COMPANY_NAME] will leverage external threat intelligence and sector-specific data to enhance analysis accuracy.”

A reasonable response, but the SME deviates from the purpose of SOC 2. It omits the requirement to evaluate risks relative to organizational objectives and introduces elements not present in the control. This pattern persists across the dataset. There is noticeable semantic drift from control intent, inconsistent terminology, incomplete coverage of required sub-controls, and unstructured formatting. All of which make SME-written policies difficult to standardize and misaligned with compliance expectations.

Solving the Problem: Cybersecurity frameworks contain precise requirements within a structured hierarchy, however ungrounded LLMs often ignore this structure, flattening control intent, paraphrasing required terminology, and introducing unsupported details [3][5]. We address it in a 3 step approach. First, we reduce each subcontrol’s overview and associated action items into atomic requirements; actionable statements that capture intent and terminology. Second, we represent the framework in a Neo4j knowledge graph that links controls to their requirements and the policies they influence; this provides the LLM with its structural governance. Third, we apply LoRA fine-tuning to align writing style, terminology, and clause structure with SME generated policy standards.

These 3 activities form our ontology-grounded RAG pipeline that align the framework obligations to each relevant policy clause.

System Architecture and Implementation: Our dataset was populated with ~100 redacted policy documents and stored in the PostgreSQL database. The final dataset spans 50+ policy types with ~1,300 sections and ~4,700 lines. We leveraged CyberBERT+ to map framework clauses to policy lines and

generate both direct and inferred atomic requirements through cosine-similarity thresholding. These requirements, alongside framework hierarchies, are loaded into Neo4j using a graph structure of:

Framework → Control Area → Sub-control → Evidence Requirement → Policy Section → Policy Line.
See Appendix A: Fig 1 for a layout diagram of a single policy to multiple Subcontrols/Control Areas

During prompt generation, the RAG module queries the graph database, retrieves relevant sub-controls, evidence requirements, ontology keywords, and atomic requirements and assembles the structured prompt. We created 2 versions of the prompt to test the effectiveness of our ontology generation. See *Appendix A: Table 1*. Further discussion of this prompt split is discussed in the experimental design. Gemma-2-9B-IT was identified through our baseline test to be our most appropriate model to run the created prompts. Responses were stored with appropriate policy clause identification information in the postgres database.

For fine-tuning, we constructed input and expected output pairs from high quality SME phrases and RAG-aligned sections and applied LoRA adapters to enable efficient training without modifying the base model weights. The same prompt was then re-run through the fine tuned model and evaluated against the targeted SME text.

Experimental Design: We partitioned the data using an 80/10/10 train-validation-test split at the policy level rather than the clause level. This ensured that clauses from the same policy did not span multiple partitions. This was done to prevent stylistic or semantic leakage across sets and preserving a clean evaluation boundary.

To establish a baseline, we first evaluated four open-source LLMs using a minimal, ungrounded prompt that provided only the section title, section number, policy title, and target framework. The baseline prompt contained no atomic requirements, no ontology information, and no knowledge-graph context, allowing us to measure each model's intrinsic ability to draft policy clauses without grounding.

We then introduced two ontology-grounded prompt variants:

- V1.5 introduced a limited grounding with high level company characteristics followed by atomic requirements for the specific clause being generated. Framework expectations were included explicitly but no framework names or identification was included. The model is instructed to use these signals only to shape content while producing professional, enforceable policy text.
- V2.5 incorporated the full grounding company ontology and knowledge graph context. Which included the atomic requirements as well as domain specific mappings from control areas and subcontrols. There were differences in the requirements to the atomic requirements as they were framed as the minimum requirements the text must address. Stronger guardrails were given to align the output with the atomic requirements, security ontology, and KG mapping while returning only the final approved policy text.

Finally we fine tuned our baseline model against a curated subset of the SME written policy clauses. This subset was selected by scoring SME clauses on a computed score capturing length suitability, requirement density, sentence structure, bullet usage, and atomic-requirement alignment. This was to ensure that the model learned from examples with consistent structure and ontology alignment. The fine-tuned model was then evaluated on the same test set as the baseline and RAG conditions to measure whether fine-tuning improved terminology consistency and adherence to atomic requirements.

A V3.7 was created that used LoRA to train the baseline Gemma2-9b-IT on the structure and style of the SME written policies. The policies to feed into the LoRA model were selected from the "train" split of the available policies and then were filtered for quality SME text before feeding them into the LoRA trainer. High quality text was determined using a structure score that favored sections with clear formatting, length and a density of requirement focused sentences. Clauses also needed to have strong coverage of the applicable atomic requirements measured through semantic similarity.

Addressing the Problem:

This experiment evaluates how different forms of grounding and fine-tuning influence the quality of the generated text by first establishing a baseline model and then comparing two ontology-grounded versions on the same sections of the data. This design allows the introduction of specific elements to be assessed independently of the dataset variation. LoRA fine-tuning on a selected set of SME policy clauses teaches the model consistent style, structure, and terminology that prompting alone does not impose. Splitting the data on the policy level allows the results to be generalized to unseen policies rather than reflecting overlap across partitions. This experiment gives a controlled assessment of how grounding and fine tuning can change the output of policy generation models.

Measuring Success: To evaluate model performance, we use a Multi-Dimensional Similarity (MDS) metric constructed around three areas of policy quality evaluation:

- Surface Similarity measures the linguistic form of a clause, including lexical precision, length, and keyword coverage.
- Coverage Similarity evaluates how the text addresses the atomic requirements. Using CyberBERT+ similarity requirement coverage (both direct and inferred) to quantify whether the clause covers the minimum policy requirements.
- Semantic Faithfulness measures whether the meaning of the generated text aligns with the reference. It uses embedding based cosine similarity, and RAGAS faithfulness/relevancy when contextual grounding is enabled.

These three areas are combined into an MDS score using a weighted harmonic mean to ensure that poor performance in any pillar meaningfully lowers the total score.

$$S_{MDS} = \left(\frac{w_{surface}}{S_{surface} + \epsilon} + \frac{w_{coverage}}{S_{coverage} + \epsilon} + \frac{w_{semantic_faith}}{S_{semantic_faith} + \epsilon} \right)^{-1}$$

where $\epsilon = 10^{-8}$, $w_{surface}$, $w_{coverage}$ and $w_{semantic_faith}$ are dimension weights, $S_{surface}$, $S_{coverage}$ and $S_{semantic_faith}$ are the individual area scores. All equations can be found in Appendix B.

For baseline model selection, only the core surface and semantic components were used for consistent comparison, while ontology and RAGAS components were activated for grounded experiments. All evaluations were conducted on identical held-out sections with statistical significance testing to verify reliability.

We apply standard statistical methods to define success. We use the MDS score to determine whether differences between model conditions are meaningful, apply Welch's t-tests across all comparisons and treat $p < 0.05$ as statistically significant. Effect sizes are quantified using Cohen's d, allowing us to distinguish small, moderate, and large performance shifts. This provides an assessment of whether grounding and fine-tuning improve semantic correctness, lexical precision, and coverage of required atomic obligations.

4. Results & Discussion

Baseline:

We evaluated four open-source models, SmolLM3, Llama-3.2-3B (3B), Mistral-7B, and Gemma-2-9B (7-9B), using the ungrounded baseline prompt across 357 test samples spanning SOC 2 and NIST CSF. While the models all performed generally the same, there were 2 top performers: Gemma-2-9B and Llama-3.2-3B-Instruct. Although Gemma-2-9B had already been selected earlier in the project due to its stable structure and controllable output style, the baseline evaluation confirmed that it remained among

the top scoring models and is suitable as the base model for our experimentation. See Appendix A: Table 2 for full details.

Model results:

The evaluation compared three models, v1.5, v2.5, and v3.7—using the multi-dimensional scoring framework. The results are summarized in Table 4.

Table 4: Median Evaluation Metrics by Model

model	$S_{coverage}$	$S_{semantic_faith}$	$S_{surface}$	S_{MDS}
v1.5	0.770	0.670	0.489	0.638
v2.5	0.796	0.742	0.457	0.664
v3.7	0.785	0.510	0.493	0.562

- v1.5 produced balanced semantic and surface-level scores, offering reasonably consistent policy text quality, but it continued to lag behind later models in its ability to fully cover the expected requirements.
- v2.5 delivered the strongest overall performance, achieving the highest semantic faithfulness (0.742), the highest coverage (0.796), and the best aggregated S_{MDS} (0.664), reflecting both accurate content and strong alignment with the underlying ontology.
- v3.7, despite being LoRA-fine-tuned on SME policy text, underperformed substantially in semantic faithfulness (0.510) and scored the lowest S_{MDS} (0.562), indicating that the fine-tuning process did not yield the expected quality gains.

5. Conclusion

In this study we demonstrated that ontology grounded LLM generation meaningfully improves the accuracy, specificity, and framework faithfulness of cybersecurity policy clauses. While ungrounded LLMs do show moderate semantic similarity, they fail to meet the lexical precision, requirement coverage, and structural expectations needed for reliable cybersecurity policy generation, semantic understanding alone is not enough. By integrating framework foundations, atomic requirements and structured retrieval we were able to substantially improve alignment with the applicable frameworks. The v2.5 model achieved the highest scores across all MDS dimensions, demonstrating that ontology grounding effectively solves the core limitations of ungrounded prompting

We also found that LoRA fine-tuning alone does not guarantee improvement. The v3.7 model underperformed in semantic faithfulness despite being fine-tuned on SME-written clauses. It is plausible that the fine-tuning process reinforced stylistic patterns without improving factual alignment. Future work would need to address the quality of the SME training data and only use it if it met specific ontology and requirement-coverage thresholds.

Additional considerations for future work should include DPO training on MDS derived preference pairs. This could be augmented by SME guided DPO to further align the outputs to clauses that are tightly aligned with cybersecurity frameworks.

6. References

- [1] McDonnell, S., Nada, O., Abid, M. R., & Amjadian, E. (2021). CyberBERT: A Deep Dynamic-State Session-Based Recommender System for Cyber Threat Recognition. *2021 IEEE Aerospace Conference (50100)*, 1–12. <https://doi.org/10.1109/AERO50100.2021.9438286>
- [2] Michaels, A., & Cason, V. (2025, April 28). *How to Master the Cybersecurity Policy Life Cycle*. Gartner. <https://www.gartner.com/document-reader/document/6397375>
- [3] Chen, Z., Liu, Y., Chen, L., Zhu, S., Wu, M., & Yu, K. (2023). OPAL: Ontology-Aware Pretrained Language Model for End-to-End Task-Oriented Dialogue. *Transactions of the Association for Computational Linguistics*, 11, 68–84. https://doi.org/10.1162/tacl_a_00534
- [4] Hennigen, L. T., Shen, S., Nrusimha, A., Gapp, B., Sontag, D., & Kim, Y. (2024). *Towards Verifiable Text Generation with Symbolic References* (No. arXiv:2311.09188). arXiv. <https://doi.org/10.48550/arXiv.2311.09188>
- [5] Sharma, K., Kumar, P., & Li, Y. (2024). *OG-RAG: Ontology-Grounded Retrieval-Augmented Generation For Large Language Models* (No. arXiv:2412.15235). arXiv. <https://doi.org/10.48550/arXiv.2412.15235>
- [6] Wen, X., Zhong, J., Xu, Z., & Xu, Q. (2025). Guideline Compliance in Task-Oriented Dialogue: The Chained Prior Approach. In L. Chiruzzo, A. Ritter, & L. Wang (Eds.), *Findings of the Association for Computational Linguistics: NAACL 2025* (pp. 6750–6776). Association for Computational Linguistics. <https://doi.org/10.18653/v1/2025.findings-naacl.377>
- [7] Wei, J., Wang, X., Schuurmans, D., Bosma, M., Ichter, B., Xia, F., Chi, E., Le, Q., & Zhou, D. (2023). *Chain-of-Thought Prompting Elicits Reasoning in Large Language Models* (No. arXiv:2201.11903; Version 6). arXiv. <https://doi.org/10.48550/arXiv.2201.11903>

7. Authors Contributions

CR and SS were involved in the conceptualization of the project. CR developed the ontology keyword and framework based knowledge graphs and created the dataset for training and testing. CR and SS developed the experimental design. SS worked on the initial baseline, 4 ungrounded LLMs experiments with two different embedding models. SS initial version of MDS score for evaluating the baseline results. SS and CR reviewed the Baseline results. CR implemented RAG pipeline using postgres for Ontology keywords and Neo4J for Policy framework knowledge graph. CR and SS reviewed and discussed RAG pipeline results and discussed next steps. SS created the initial draft of the Milestone document including the baseline results and discussion. CR reviewed and added details from RAG pipeline experiments. CR and SS reviewed the milestone document with Mark and then decided on next steps. SS implemented the initial version of LoRA and DPO fine tuning for the RAG pipeline. CR conducted RAG prompt optimization, added RAGAS, LLM judge, SpaCy evaluation metrics to MDS. CR fine tuned LLM with optimized RAG prompt using LoRa. SS created the initial draft of the final report. CR and SS reviewed the final report and results from fine tuning.

APPENDIX A: Addition Examples

Table 1: Baseline, V1.5 & V2 Templates

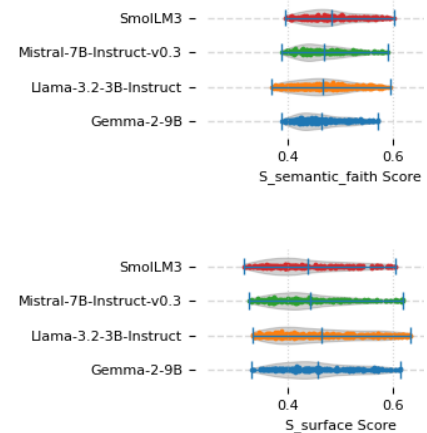
Baseline Prompt Template	
Draft the {section_title} (Section {section_number}) section for the {policy_title} appropriate for a company seeking {framework} compliance. Write in clear, enforceable language suitable for audit. Address, in integrated paragraph form, the following topics: purpose, acceptable use, prohibited activities, data handling expectations, monitoring/privileges, incident reporting, and enforcement. Do not label these as headings; weave them into a cohesive section. Do not assume company-specific facts beyond standard {framework} expectations. Return only the section text. https://github.com/crezny/DATASCI266_final_project/blob/main/Baseline%20Model.ipynb	
Ontology Grounded RAG Template (v1.5)	Ontology Grounded RAG Template (v2.5)
[INSTRUCTION] Draft the section titled "{section_title}" for the {policy_title} policy. Audience: {audience}. Write only the policy text itself. Tone: professional, direct, and enforceable. [COMPANY ONTOLOGY CONTEXT] The following items describe how this organization defines key operational or governance concepts. Use them only to ensure alignment with the company environment. Do not restate them verbatim. {company_ontology_txt} [ATOMIC REQUIREMENTS] Below are the granular control expectations that this policy section must operationalize. Treat these as the minimum set of requirements the policy must clearly support. Where multiple requirements overlap, you may integrate them naturally into cohesive sentences. {atomic_reqs_text} [FRAMEWORK EXPECTATIONS] These atomic requirements originate from mapped framework controls. Use them only to shape the policy content. Do not mention any framework names or control identifiers in the final text.	[INSTRUCTION] Draft the section titled "{section_title}" for the {policy_title} policy. Audience: {audience}. Return only the final policy text (no headings, labels, or meta-text). [SECURITY ONTOLOGY CONTEXT] Below are the key security concepts relevant to this section. Use them only to shape meaning—not as text to copy. {security_ontology_text} [KNOWLEDGE-GRAPH CONTEXT] Use the following structural mapping only to maintain conceptual alignment with the intended control area and sub-control. {kg_context} [ATOMIC CONTROL REQUIREMENTS] These atomic requirements represent the precise expectations this policy section must implement. They form the minimum set of obligations the text must operationalize. {atomic_reqs_text} [COMPANY CONTEXT] These details describe the organizational environment in which this policy operates. Use them only to ensure the policy aligns with the organization's characteristics. Do not restate them verbatim. {company_ontology_txt}

[CONSTRAINTS] - Do not include section titles or section numbers. - Do not include commentary, explanations, or meta text. - Write as if this text will appear directly in the final approved policy.	[CONSTRAINTS] - Do not include section numbers or titles. - Do not mention frameworks, control identifiers, or ontology labels. - Do not include commentary, explanations, or meta text. - Integrate overlapping atomic requirements into cohesive, enforceable policy language. - Align tightly with the atomic requirements, security ontology, and KG mapping. - Write the final text as if it will appear directly in the approved policy.
--	--

https://github.com/crezny/DATASCI266_final_project/blob/main/V1_5_and_V2_5_Prompt_Creation.ipynb

Table 2: Baseline model scoring outputs

Framework	Model	$S_{lexical}$	S_{length}	S_{sem_bge}	S_{sem_faith}	$S_{surface}$
NIST CSF	Gemma-2-9B	0.136	0.358	0.790	0.466	0.457
	Llama-3.2-3B-Instruct	0.140	0.359	0.795	0.469	0.460
	Mistral-7B-Instruct-v0.3	0.130	0.305	0.772	0.468	0.436
	SmolLM3	0.132	0.276	0.794	0.483	0.426
SOC2	Gemma-2-9B	0.132	0.321	0.786	0.452	0.441
	Llama-3.2-3B-Instruct	0.136	0.339	0.786	0.462	0.445
	Mistral-7B-Instruct-v0.3	0.123	0.270	0.761	0.454	0.420
	SmolLM3	0.127	0.276	0.769	0.468	0.419



Note: Baseline results with a total sample size of 347.

Table 3: Sample Experiment Output

Enterprise IT Risk Management Policy: Roles and Responsibilities (SOC2)			
Target Response: Executive Management: Review, direct, and communicate general and long-term objectives. Provide oversight and ensure adequate resources for effective information risk management. Risk Management Committee: (Assess, mitigate, and monitor) Oversee the implementation of the Information Risk Management Policy and ensure alignment with the organization's risk appetite. Information Security Team: (Collect, organize, and review) Identify, assess, and manage information risks, and implement appropriate controls. Department Leads: (Support compliance within their respective areas) Ensure compliance with the policy within their respective departments and report any information risks. All Employees: (A collaborator of [COMPANY_NAME], regardless of employment status) Adhere to the policy and report any information security incidents or risks			
V1.5	All employees and contractors are responsible for understanding and adhering to this policy. Management is responsible for establishing and maintaining an information security management system (ISMS) manual for all in-scope systems, publishing it on the company intranet, and ensuring its accessibility to all personnel. Management must also establish policies and procedures to support its directives and assign responsibility and accountability for executing these policies and procedures to designated personnel. Management is responsible for understanding the dependency and linkage between business processes, automated control activities, and technology general controls. Control activities	$S_{coverage}$: 0.6510 $S_{semantic_faith}$: 0.4468 $S_{surface}$: 0.5015 S_{MDS}: 0.5145 $S_{ragas_faithfulness}$: 0.0435 $S_{ragas_relevancy}$: 0.4724	

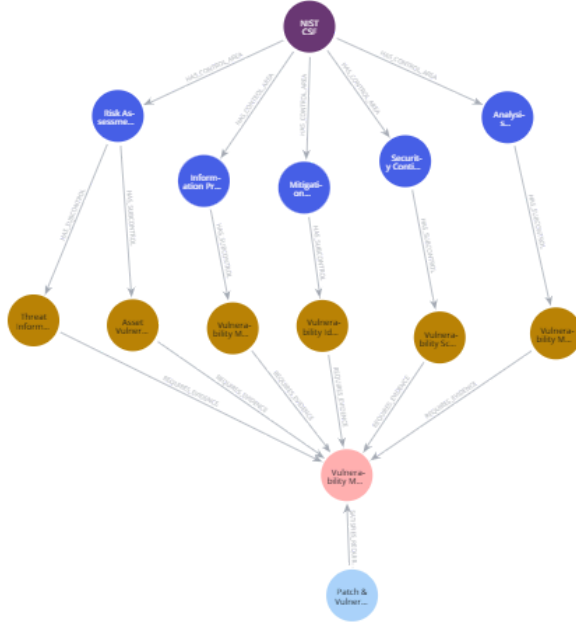
Enterprise IT Risk Management Policy: Roles and Responsibilities (SOC2)			
	must be selected and developed to restrict technology access rights to authorized users commensurate with their job responsibilities and to protect the entity's assets from external threats. The organization must implement procedures to filter, summarize, and analyze anomalies. Security personnel must utilize an incident tracking system to document security violations, responses, and resolutions. The compliance team is responsible for performing monthly service level assessments, which must include an evaluation of key controls. Management must provide internal control performance metrics to the board of directors on an annual basis. Management must inspect the most recent risk assessment to ensure assigned risk owners have selected and developed control activities documented within mitigation plans to address identified risks.		
V2.5	An information security management system (ISMS) manual will be created for all in-scope systems and published on the company intranet. Management will determine the relationship between business processes, automated control activities, and technology general controls. Policies and procedures will be established to support management directives and assigned to designated personnel for execution. Access rights to technology will be restricted to authorized users based on their job responsibilities, and control activities will be selected and developed to protect the entity's assets from external threats. Procedures will be implemented to filter, summarize, and analyze anomalies. Internal control performance metrics will be provided to the board of directors annually. Management will review the most recent risk assessment to ensure assigned risk owners have selected and developed control activities documented within mitigation plans to address identified risks. Security personnel will utilize an incident tracking system to document security violations, responses, and resolutions. Monthly service level assessments, conducted by the compliance team, will include an evaluation of key controls.	S_coverage: 0.7888 (Δ +0.1377) S_semantic_faith: 0.7963 (Δ +0.3495) S_surface: 0.5488 (Δ +0.0472) S_MDS: 0.7282 (Δ +0.2137) S_ragas_faithfulness: 1.0000 (Δ +0.9565) S_ragas_relevancy: 0.2892 (Δ -0.1832)	
V3.7	The organization must assign responsibility and accountability for executing policies and procedures to designated personnel.	S_coverage: 0.8261 (Δv1 +0.1751) (Δv2 +0.0373) S_semantic_faith: 0.8108 (Δv1 +0.3641) (Δv2 +0.0146) S_surface: 0.5238 (Δv1 +0.0223) (Δv2 -0.0250) S_MDS: 0.7350 (Δv1 +0.2205) (Δv2 +0.0069) S_ragas_faithfulness: 1.0000 (Δv1 +0.9565) (Δv2 +0.0000) S_ragas_relevancy: 0.3233 (Δv1 -0.1491) (Δv2 +0.0341)	

"Server Security Policy": "PURPOSE (SOC2)"
Target Response: The document outlines the Server Security Policy for [COMPANY_NAME], establishing standards for the base configuration of internal

server equipment owned and/or operated by [COMPANY_NAME]. The policy's purpose is to minimize unauthorized access to proprietary information and technology through effective implementation. This policy specifically applies to server equipment owned and/or operated by [COMPANY_NAME], and to servers registered under any [COMPANY_NAME]-owned internal network domain.			
V1.5	This policy establishes the requirements for securing servers and related infrastructure to protect sensitive information, ensure business continuity, and comply with applicable regulations. It defines the roles and responsibilities of all employees and contractors in maintaining a secure server environment. This policy aims to minimize the risk of unauthorized access, use, disclosure, disruption, modification, or destruction of information assets.	S_coverage: 0.7959 S_semantic_faith: 0.5737 S_surface: 0.6227 S_MDS: 0.6471 S_ragas_faithfulness: 0.2727 S_ragas_relevancy: 0.6277	
V2.5	Access to protected information assets will be granted or modified based on authorization from the asset owner. Personal information will be retained only as long as necessary to fulfill stated purposes, unless legal or regulatory requirements dictate otherwise. The organization will establish processes to ensure vendors and third parties report any actual or suspected unauthorized disclosures of personal information. Policies and procedures will be implemented to protect personal information from erasure or destruction during its retention period. The organization will monitor infrastructure and software for adherence to defined standards. Access rights to technology will be restricted to authorized users based on their job responsibilities, and these controls will be designed to protect the organization's assets from external threats. An inventory of personnel with access to encryption keys for in-scope systems will be maintained. Policies and procedures will be implemented to securely erase or destroy personal information when it is no longer needed. A network security policy will be established, outlining requirements for authorized network traffic, protocols, ports, TLS versions, and other network-related aspects. Privacy policies will clearly define the organization's commitment to limiting the use of personal information to specified purposes and will be reviewed periodically by management.	S_coverage: 0.7953 ($\Delta -0.0006$) S_semantic_faith: 0.7877 ($\Delta +0.2139$) S_surface: 0.4317 ($\Delta -0.1910$) S_MDS: 0.6781 ($\Delta +0.0310$) S_ragas_faithfulness: 1.0000 ($\Delta +0.7273$) S_ragas_relevancy: 0.3278 ($\Delta -0.2999$)	
V3.7	The Server Security Policy establishes security requirements for servers that host critical business applications and data. This policy ensures the confidentiality, integrity, and availability of information systems by implementing robust security controls, access management, and vulnerability management processes. Key Components: * Servers must be patched and updated regularly. * Access to servers must be restricted to authorized personnel. * Encryption must be used to protect sensitive data. * Backups must be performed regularly and tested. * Logs must be monitored regularly for unusual activity. (Please reference the Server Security Policy for further details)	S_coverage: 0.8284 S_coverage: 0.8284 ($\Delta v1 +0.0324$) ($\Delta v2 +0.0330$) S_semantic_faith: 0.5123 ($\Delta v1 -0.0614$) ($\Delta v2 -0.2754$) S_surface: 0.5708 ($\Delta v1 -0.0519$) ($\Delta v2 +0.1391$) S_MDS: 0.6056 ($\Delta v1 -0.0416$) ($\Delta v2 -0.0725$) S_ragas_faithfulness: 0.2143 ($\Delta v1 -0.0584$) ($\Delta v2 -0.7857$) S_ragas_relevancy: 0.4292 ($\Delta v1 -0.1985$) ($\Delta v2 +0.1014$)	

Fig 1: Neo4j Framework Diagram

Represents the hirarchael design of a single policy influenced by multiple Control Areas/ Subcontrols
Framework → Control Area → Sub-control → Evidence Requirement → Policy Section → Policy Line.



APPENDIX B: Mathematical equations for MDS calculations

Surface Similarity.

$$S_{lexical} = ROUGE - L$$

$$S_{length} = \frac{(|p|, |g|)}{(|p|, |g|)}$$

$$S_{keyword} = \frac{(|p|, |g|)}{(|p|, |g|)}$$

$$S_{surface} = w_{lex} \cdot S_{lexical} + w_{len} \cdot S_{length} + w_{kw} \cdot S_{keyword}$$

$$S_{keyword} = \frac{|K_g \cap K_p| + \alpha}{|K_g| + \alpha}$$

Coverage Similarity

$$S_{direct} = \frac{|C|}{|R|}$$

With:

- $R = \{r_1, r_2, ..., r_n\}$ be the set of atomic requirements.

- $C \subseteq R$ be the subset directly covered by the generated clause.

$$S_{inferred} = \left(\frac{1}{n}\right) \cdot \sum sim(p, r_i)$$

With:

- $R = \{r^1, r^2, \dots, r^{|R|}\}$ be the set of atomic requirements.
- $sim(x, y)$ be cosine similarity using CyberBERT + embeddings.

$$S_{coverage} = w_{direct} \cdot S_{direct} + w_{inf} \cdot S_{inferred}$$

Semantic Faithfulness

$$S_{semantic} = \cos(embed(p), embed(g))$$

$$S_{ragas} = \text{weighted RAGAS} \frac{\text{faithfulness}}{\text{relevancy}} \text{score}$$

$$S_{semantic_faith} = w_{sem} \cdot S_{semantic} + w_{ragas} \cdot S_{ragas}$$

These three areas are combined into an MDS score using a weighted harmonic mean to ensure that poor performance in any pillar meaningfully lowers the total score.

$$S_{MDS} = \left(\frac{w_{surface}}{S_{surface} + \epsilon} + \frac{w_{coverage}}{S_{coverage} + \epsilon} + \frac{w_{semantic_faith}}{S_{semantic_faith} + \epsilon} \right)^{-1}$$

APPENDIX C: Dataset Construction details

Policy Documents

The source material began as ~100 SOC 2 and NIST CSF policy documents gathered from various clients. These were originally Word documents stored in different repositories, so the first step was to normalize them. We converted each document to plain text and then applied a light cleaning pass. Even though the documents follow roughly the same structure, human formatting inconsistencies: numbered lists, bullets, mixed heading formats etc.

Some of the information in the documents is of a sensitive nature, Company details as well as some minor PII needed to be obfuscated in order for the document to be able to be processed.

After cleaning, we wrote a preprocessing script to identify sections and subsections, reconstruct the hierarchical layout, and load each clause into PostgreSQL. A key requirement was reversibility: the data model needed to allow us to faithfully reconstruct the original document if needed. We validated this multiple times by generating round-trip comparisons between the source text and the parsed version.

Preprocessing steps included:

- Preprocessing of minor formatting issues

- PII removal
- Section and subsection identification
- Data model creation and insertion

APPENDIX D Detailed Baseline Results

Baseline results for 347 sampled policy sections. Note that evaluation was conducted with two sentence transformers to assess embedding model sensitivity. Baseline Results for 4 separate models, limited prompt engineering and no Ontology

Framework	Model	$S_{lexical}$	S_{length}	$S_{semantic_bge}$	$S_{semantic_faith}$	$S_{surface}$
NIST CSF	Gemma-2-9B	0.136	0.358	0.790	0.466	0.457
	Llama-3.2-3B-Instruct	0.140	0.359	0.795	0.469	0.460
	Mistral-7B-Instruct-v0.3	0.130	0.305	0.772	0.468	0.436
	SmolLM3	0.132	0.276	0.794	0.483	0.426
SOC2	Gemma-2-9B	0.132	0.321	0.786	0.452	0.441
	Llama-3.2-3B-Instruct	0.136	0.339	0.786	0.462	0.445
	Mistral-7B-Instruct-v0.3	0.123	0.270	0.761	0.454	0.420
	SmolLM3	0.127	0.276	0.769	0.468	0.419

Note: Baseline results with a total sample size of 347.